

ORP.6 Cloud-Identitäts- und Zugriffsmanagement

1 Beschreibung

1.1 Einleitung

Das Identitäts- und Zugriffsmanagement (Identity and Access Management, IAM) in Cloud-Umgebungen unterscheidet sich grundlegend von klassischen On-Premises-Ansätzen. Neben der Verwaltung menschlicher Benutzer rücken in der Cloud maschinelle und programmgesteuerte Identitäten wie Dienste, Anwendungen, Serverless-Funktionen und Container in den Fokus, die über APIs auf Ressourcen zugreifen. Die Verwaltung erfolgt über komplexe Richtlinien (Policies) in hochdynamischen Umgebungen. Konzepte wie föderierte Identitäten, temporäre Sicherheitsanmeldeinformationen und die geteilte Verantwortung (Shared Responsibility Model) zwischen Cloud-Anbieter und Cloud-Kunde sind dabei von zentraler Bedeutung.

1.2 Zielsetzung

Ziel dieses Bausteins ist es, ein robustes und sicheres Identitäts- und Zugriffsmanagement für Cloud-Umgebungen zu etablieren. Es soll sichergestellt werden, dass der Grundsatz der geringsten Berechtigung (Least Privilege) für sämtliche menschlichen und maschinellen Identitäten umgesetzt wird, um unautorisierte Zugriffe zu verhindern und eine lückenlose Nachvollziehbarkeit sicherheitsrelevanter Aktionen zu gewährleisten.

1.3 Abgrenzung und Modellierung

Der Baustein ORP.6 ist auf alle genutzten Public- und Private-Cloud-Umgebungen anzuwenden. Er konkretisiert die allgemeinen Anforderungen des Bausteins ORP.4 Identitäts- und Berechtigungsmanagement für den spezifischen Cloud-Kontext.

Voraussetzung für die Anwendung ist, dass die grundsätzlichen Vorgaben für die Cloud-Nutzung bereits umgesetzt sind (siehe OPS.2.2 Cloud-Nutzung). Aspekte der Container-Sicherheit werden in SYS.1.6 Containerisierung behandelt, während die sichere Anwendungsentwicklung in CON.8 Software-Entwicklung (auftragnehmende Seite) oder CON.10 Entwicklung von Webanwendungen berücksichtigt wird. Diese Themen sind nicht Bestandteil dieses Bausteins.

2 Gefährdungslage

Für das Cloud-Identitäts- und Zugriffsmanagement sind folgende spezifische Gefährdungen von besonderer Bedeutung:

Überprivilegierte Identitäten

Benutzer und insbesondere Dienste (Service Principals, Workload-Identitäten) erhalten in Cloud-Umgebungen häufig weitaus mehr Berechtigungen, als für ihre eigentliche Aufgabe notwendig ist. Aufgrund der Komplexität von feingranularen Berechtigungen werden oft vordefinierte, zu breite Rollen vergeben. Eine Kompromittierung einer solchen Identität ermöglicht es Angreifern, weitreichenden Schaden in der Cloud-Infrastruktur anzurichten.

Kompromittierung langlebiger Zugangsdaten

Für den programmatischen Zugriff werden häufig langlebige statische Zugangsdaten (wie API-Schlüssel oder Secrets) erstellt und unzureichend geschützt in Anwendungen oder Konfigurationsdateien hinterlegt. Werden diese kompromittiert, erlangen unbefugte Dritte dauerhaft und oft unbemerkt Zugriff auf Cloud-Ressourcen.

Unbeabsichtigte Berechtigungseskalation

Die Kombination mehrerer IAM-Richtlinien auf verschiedenen strukturellen Ebenen (Organisation, Ordner, Projekt, Ressource) führt zu schwer nachvollziehbaren kumulativen Rechten. Angreifer können Konfigurationsschwächen ausnutzen, um ihre eigenen Berechtigungen über die Verkettung komplexer Richtlinien gezielt zu erweitern (Privilege Escalation).

Unsichere Konfiguration föderierter Identitäten

Eine fehlerhafte Konfiguration der Vertrauensstellung zwischen einem lokalen Identitätsanbieter und dem Cloud-IAM-System kann es Angreifern ermöglichen, sich mit kompromittierten lokalen Konten unautorisiert Zugriff auf die Cloud-Infrastruktur zu verschaffen oder den föderierten Identitätsanbieter komplett zu umgehen.

Mangelnde Übersicht in Multi-Cloud-Umgebungen

Jeder Cloud-Anbieter nutzt ein proprietäres IAM-Modell mit unterschiedlichen Konzepten und Begrifflichkeiten. Dies erschwert die Durchsetzung einer einheitlichen Sicherheitsrichtlinie massiv und führt zu einer unübersichtlichen Berechtigungslandschaft, in der verwaiste Konten oder Fehlkonfigurationen oft unentdeckt bleiben.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins ORP.6 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
-----------------	--------

Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Informationssicherheitsbeauftragter (ISB), Planer

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

ORP.6.A1 Planung des Cloud-Identitäts- und Zugriffsmanagements (B) [Planer]

Vor der Nutzung von Cloud-Diensten MUSS ein spezifisches IAM-Konzept für die Cloud-Umgebung geplant werden. Darin MÜSSEN die Verwaltung von Identitäten, die Authentifizierungsmechanismen und die Struktur der Berechtigungsvergabe festgelegt werden.

ORP.6.A2 Richtlinie zur Verwaltung von Cloud-Identitäten (B) [Informationssicherheitsbeauftragter (ISB)]

Es MUSS eine Richtlinie erstellt werden, die den gesamten Lebenszyklus von Cloud-Identitäten regelt. Diese MUSS verbindliche Vorgaben für die Erstellung, Änderung, Deaktivierung und Löschung von menschlichen und nicht-menschlichen Identitäten (Dienstkonten) enthalten.

ORP.6.A3 Absicherung des Haupt-Administratorkontos (B)

Das initiale Haupt-Administratorkonto (Root-Account) der Cloud-Umgebung MUSS durch ein starkes Passwort und eine Multi-Faktor-Authentifizierung (MFA) geschützt werden. Das Konto DARF NICHT für alltägliche administrative Aufgaben oder den regulären Betrieb verwendet werden.

ORP.6.A4 Einführung eines grundlegenden Rollenkonzepts (B)

Für die Cloud-Umgebung MUSS ein rollenbasiertes Zugriffskonzept (Role-Based Access Control, RBAC) umgesetzt werden. Dieses MUSS zumindest eine Trennung zwischen lesenden, bearbeitenden und verwaltenden Rechten auf Cloud-Ressourcen sicherstellen.

ORP.6.A5 Erzwingung der Multi-Faktor-Authentifizierung (B)

Für alle Benutzer, die über Berechtigungen zur Änderung von Cloud-Konfigurationen, IAM-Richtlinien oder Daten verfügen, MUSS die Verwendung von Multi-Faktor-Authentifizierung (MFA) technisch erzwungen werden.

ORP.6.A6 Protokollierung von IAM-Aktivitäten (B)

Alle sicherheitsrelevanten IAM-Ereignisse MÜSSEN lückenlos protokolliert werden. Dazu gehören insbesondere Anmeldeversuche, administrative API-Aufrufe sowie alle Änderungen an Identitäten und Berechtigungen. Die Protokolldaten MÜSSEN zentral gesammelt und vor Manipulation geschützt werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

ORP.6.A7 Konzeption von Berechtigungen nach dem Least-Privilege-Prinzip (S) [Planer]

Berechtigungen SOLLTEN so granular wie möglich vergeben werden. Anstelle von breit gefassten, vordefinierten Standardrollen SOLLTEN aufgabenbezogene, benutzerspezifische Rollen erstellt werden, die exakt nur die für die jeweilige Aufgabe notwendigen Berechtigungen enthalten.

ORP.6.A8 Nutzung von Föderation statt nativer Cloud-Benutzer (S)

Menschliche Benutzer SOLLTEN sich über einen zentralen, vertrauenswürdigen Identitätsanbieter (Identity Provider) authentifizieren. Die direkte Erstellung von Cloud-nativen Benutzern mit eigenen Passwörtern in der Cloud-Umgebung SOLLTE vermieden werden.

ORP.6.A9 Einsatz temporärer Anmeldeinformationen für maschinellen Zugriff (S)

Für den Zugriff durch Anwendungen, Skripte oder Cloud-Dienste SOLLTEN Mechanismen für temporäre, rollenbasierte Anmeldeinformationen genutzt werden. Die Nutzung von langlebigen, statischen API-Schlüsseln SOLLTE vermieden werden.

ORP.6.A10 Regelmäßige Überprüfung der Berechtigungen (S)

Die zugewiesenen Berechtigungen für alle Identitäten SOLLTEN in regelmäßigen Abständen auf ihre Erforderlichkeit überprüft werden (Access Reviews). Nicht mehr benötigte oder überprivilegierte Zugriffe SOLLTEN umgehend entfernt werden. Dieser Prozess SOLLTE nach Möglichkeit automatisiert unterstützt werden.

ORP.6.A11 Nutzung von bedingtem Zugriff (S)

Der Zugriff auf Cloud-Ressourcen SOLLTE an dynamische Bedingungen geknüpft werden (Conditional Access). Die Richtlinien SOLLTEN Faktoren wie den geografischen Standort des Benutzers, den Sicherheitszustand des Endgeräts oder das erkannte Risikoniveau der Anmeldung berücksichtigen.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

ORP.6.A12 Einsatz von Just-in-Time-Zugriff für administrative Rollen (H)

Hochprivilegierte administrative Berechtigungen SOLLTEN den Administratoren nicht permanent zugewiesen sein. Sie SOLLTEN nur bei Bedarf, für einen zeitlich streng begrenzten Zeitraum und nach einem dokumentierten Genehmigungsprozess aktiviert werden (Just-in-Time-Vergabe). (C, I, A)

ORP.6.A13 Kontinuierliche Überwachung der Berechtigungsstruktur (H)

Es SOLLTEN spezialisierte Werkzeuge (z. B. Cloud Security Posture Management, CSPM) eingesetzt werden, die die IAM-Konfiguration kontinuierlich auf Fehlkonfigurationen, weitreichende Berechtigungen und Abweichungen vom Soll-Zustand scannen und automatisiert alarmieren. (C, I, A)

ORP.6.A14 Implementierung von Berechtigungsgrenzen (H)

Um eine unkontrollierte Ausweitung von Rechten in komplexen Umgebungen zu verhindern, SOLLTEN technische Berechtigungsgrenzen (Permissions Boundaries) definiert werden. Diese legen die maximal möglichen Berechtigungen fest, die eine Identität erhalten kann, auch wenn durch andere Richtlinien temporär höhere Rechte angefordert werden. (C, I)

ORP.6.A15 Zentrales IAM für Multi-Cloud-Umgebungen (H)

Werden mehrere Cloud-Plattformen unterschiedlicher Anbieter gleichzeitig genutzt, SOLLTE eine zentrale IAM-Management-Lösung eingesetzt werden, um eine plattformübergreifende, einheitliche Übersicht und Kontrolle über die Berechtigungen sicherzustellen. (C, I, A)

ORP.6.A16 Absicherung von Workload-Identitäten (H)

Die Authentifizierung zwischen externen Diensten (beispielsweise CI/CD-Pipelines) und der Cloud-Umgebung SOLLTE über kurzlebige, zertifikatsbasierte Vertrauensstellungen (Workload Identity Federation) anstelle von statischen Geheimnissen abgesichert werden. (C, I)

4 Weiterführende Informationen

4.1 Wissenswertes

Das BSI hat im „Cloud Computing Compliance Criteria Catalogue“ (C5) in den Kapiteln zu Identitäts- und Berechtigungsmanagement (IAM) grundlegende Sicherheitskriterien für

Cloud-Dienste formuliert.

Zudem bieten einschlägige Branchenstandards wie die „CIS Foundations Benchmarks“ der Center for Internet Security konkrete Härtungsempfehlungen für das IAM der großen Hyperscaler. Die Open Web Application Security Project (OWASP) beschreibt in ihren Publikationen zur Cloud-Sicherheit spezifische Angriffsvektoren im Bereich Cloud IAM und passende Gegenmaßnahmen.

Kreuzreferenztabelle zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein ORP.6 von Bedeutung.

Anforderung	G 0.18	G 0.19	G 0.23	G 0.31	G 0.32	G 0.42
ORP.6.A1 (B)	X					
ORP.6.A2 (B)	X				X	
ORP.6.A3 (B)		X	X		X	X
ORP.6.A4 (B)			X	X	X	
ORP.6.A5 (B)		X	X			X
ORP.6.A6 (B)			X	X	X	
ORP.6.A7 (S)					X	
ORP.6.A8 (S)	X		X			
ORP.6.A9 (S)		X	X			
ORP.6.A10 (S)					X	

ORP.6.A11 (S)			X			X
ORP.6.A1 2 (H)			X		X	
ORP.6.A1 3 (H)	X		X	X		
ORP.6.A1 4 (H)	X				X	
ORP.6.A1 5 (H)	X			X	X	
ORP.6.A1 6 (H)		X	X			